

# SENTINEL-CPS

## Security Requirements Document (SRD)

### Securing Cyber Physical Systems in a Remote IoT Lab: A Zero-Trust Edge Gateway Architecture Utilizing eBPF and AI Threat Detection

|                      |                                                                                                                                                     |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Project Name         | Sentinel-CPS                                                                                                                                        |
| Architecture Version | 10.0                                                                                                                                                |
| Author               | Tarique Chowdhury                                                                                                                                   |
| Advisor              | Dr. George Li                                                                                                                                       |
| Date                 | June 2, 2026                                                                                                                                        |
| Document Status      | Draft for thesis development and advisor review                                                                                                     |
| Primary Focus        | Security requirements for Zero-Trust gateway access, HLAC network enforcement, hardware isolation, ESP-NOW integrity, and eBPF/AI threat mitigation |

Prepared for Master's Thesis Development

## Document Control

This Security Requirements Document (SRD) defines the defensive requirements for the current Sentinel-CPS Version 10.0 architecture. It preserves the approved thesis title while aligning the security baseline with the remote educational sandbox, Port 8080 unified C2 application, TV-as-a-Track physical execution model, analog light-sensor navigation, and planned eBPF/AI mitigation pipeline.

| Version | Date         | Prepared By       | Summary of Update                                                                                                                                                                                                                                                                                                    |
|---------|--------------|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 10.0    | June 2, 2026 | Tarique Chowdhury | Updated the SRD for Sentinel-CPS v10.0: strict SSH identity enforcement, VPN/RDP Bastion Host ingress, nftables default-drop HLAC, mDNS resilience, USB and serial isolation, deprecation of camera/video payloads, ESP-NOW CCMP integrity, Smart TV display segregation, and eBPF/AI-based STOP/severance response. |

## Contents

1. Introduction
2. Security Scope and Trust Assumptions
3. Access Control and Identity Management (SR-A)
4. Network Perimeter Defense (SR-N)
5. Hardware and Physical Security (SR-H)
6. Wireless Security and Integrity (SR-W)
7. Runtime Observability and Active Threat Mitigation (SR-O)
8. Security Validation Criteria
9. Security Traceability Summary

## 1. Introduction

This Security Requirements Document (SRD) defines the comprehensive security architecture and defensive requirements for the Sentinel Edge Gateway and its integrated Cyber-Physical System (CPS). It specifies the controls required across the management plane, network perimeter, physical hardware layer, wireless telemetry layer, and runtime observability environment to enforce a Zero-Trust perimeter around Sentinel-CPS.

The requirements are written for the Version 10.0 architecture, in which the Gateway runs natively on a Raspberry Pi, exposes a unified C2 web application on TCP Port 8080, communicates with a tethered ESP32 Hub through /dev/ttyUSB0, and supports autonomous ESP32 vehicles navigating a Smart TV-based physical track. The SRD is intended to guide implementation, validation, and thesis review rather than replace institutional network policy or enterprise security governance.

## 2. Security Scope and Trust Assumptions

- **Approved thesis title:** Securing Cyber Physical Systems in a Remote IoT Lab: A Zero-Trust Edge Gateway Architecture Utilizing eBPF and AI Threat Detection
- **Zero-Trust premise:** Remote users, edge devices, display endpoints, and wireless traffic are not implicitly trusted. Each layer receives only the minimum access required for its function.
- **Gateway role:** The Raspberry Pi Gateway is the central control and observability chokepoint. Administrative access must be cryptographically authenticated and network-restricted.
- **Remote access model:** Remote users interact with the lab through the university VPN and a Windows Bastion Host reached by RDP; the Gateway is not exposed directly to the public internet.
- **Display endpoint model:** The Smart TV is authorized for Port 8080 display/rendering functions only and is not considered an administrative endpoint.
- **Wireless model:** ESP-NOW traffic is treated as exposed to spoofing and injection attempts unless protected by peer controls and CCMP encryption.
- **Runtime monitoring model:** Application logs alone are insufficient. Host-level eBPF tracing of serial read/write behavior is required to support anomaly detection and mitigation.

## 3. Access Control and Identity Management (SR-A)

To prevent unauthorized administrative access to the core infrastructure, the Gateway must enforce strict identity verification and ensure that remote access flows through sanctioned university and lab control points.

| ID    | Security Requirement                                                                                                                                                 | Control Rationale                                                                                                       | Validation Evidence                                                                                            |
|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| SR-A1 | Cryptographic Identity: Password authentication must be globally disabled at the SSH daemon level using PasswordAuthentication no and equivalent hardening settings. | Prevents password brute force, credential reuse, and unauthorized administrative fallback access.                       | sshd_config review; SSH password login denial test; service restart evidence.                                  |
| SR-A2 | Key-Based Enforcement: Administrative access must be limited to users or endpoints possessing authorized Ed25519 cryptographic keys.                                 | Ensures that MAC whitelisting is reinforced by Layer 7 cryptographic identity enforcement.                              | authorized_keys review; successful key-based login from approved admin host; failed login without private key. |
| SR-A3 | VPN-Gated Bastion Host: Remote operational access must be routed through the university managed Student VPN before entering the lab workflow.                        | Prevents direct off-campus exposure of the Gateway and concentrates remote ingress behind institutional authentication. | VPN/RDP workflow demonstration; network reachability test from off-campus without VPN.                         |

| ID    | Security Requirement                                                                                                                                                                               | Control Rationale                                                                                               | Validation Evidence                                                                               |
|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| SR-A4 | RDP Gateway: Users must utilize an RDP session to the physically co-located Windows lab workstation, which serves as the sole authorized Bastion Host for interacting with Gateway infrastructure. | Concentrates remote student interaction at a controlled endpoint rather than exposing Gateway services broadly. | Bastion Host MAC/IP inventory; RDP workflow evidence; Gateway access test from Bastion Host only. |
| SR-A5 | Least-Privilege Administration: Display endpoints and student-facing sandbox devices must not possess administrative credentials, SSH keys, or management access to the Gateway.                   | Separates observation and educational use from Gateway administration.                                          | Credential inventory; Smart TV Port 22 denial test; sandbox host privilege review.                |

## 4. Network Perimeter Defense (SR-N)

The Gateway must defend against lateral movement, unauthorized inbound traffic, and unintended routing behavior. Network security is enforced through nftables, service-specific access rules, and endpoint-specific trust boundaries.

| ID    | Security Requirement                                                                                                                                                                                                                                                                                                                | Control Rationale                                                                                                           | Validation Evidence                                                                      |
|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|
| SR-N1 | Layer 2 HLAC: The host-level nftables firewall must enforce a strict default-drop policy for all inbound and forwarded traffic so the Raspberry Pi cannot act as a rogue network bridge.                                                                                                                                            | Limits lateral movement and prevents the Gateway from becoming an unmanaged pass-through between networks.                  | nftables ruleset review; default-drop test; forwarding-disabled/blocked verification.    |
| SR-N2 | Tiered MAC Whitelisting: Inbound SSH on TCP Port 22 must be restricted to approved administrative endpoints such as the Bastion Host and primary administrative MacBook. Inbound C2 traffic on TCP Port 8080 must be restricted to approved web/display endpoints, including administrative machines and the Smart TV Display Node. | Separates management privileges from display/web access and applies least privilege at the service level.                   | Port 22/8080 tests from approved and unapproved MAC addresses; Smart TV SSH denial test. |
| SR-N3 | mDNS Resilience: The firewall must explicitly permit multicast UDP Port 5353 for avahi-daemon so the Gateway hostname <code>iot-pi.local</code> remains reachable despite dynamic DHCP lease changes.                                                                                                                               | Maintains operational resilience after denial or absence of static DHCP reservations while avoiding broad network exposure. | avahi-daemon status; <code>iot-pi.local</code> resolution test; UDP 5353 rule review.    |
| SR-N4 | No Direct Public Exposure: The Gateway must not be exposed directly to the public internet. Remote management must be mediated through the VPN/RDP Bastion Host workflow.                                                                                                                                                           | Reduces public attack surface and preserves institutional access control boundaries.                                        | External reachability scan; routing table review; VPN/RDP access evidence.               |
| SR-N5 | Service Minimization: Only services required for thesis operation should be listening on the Gateway, with SSH and the C2 web application treated as explicitly controlled exceptions.                                                                                                                                              | Reduces exploitable service surface on the bare-metal Gateway.                                                              | <code>ss -tln</code> output; service inventory; disabled/removed unnecessary daemons.    |

## 5. Hardware and Physical Security (SR-H)

The physical attack surface of the bare-metal Gateway and autonomous CPS must be actively reduced. Hardware controls are required because Sentinel-CPS includes real actuators, physical interfaces, and removable peripheral risks.

| ID    | Security Requirement                                                                                                                                                                | Control Rationale                                                                                                                               | Validation Evidence                                                                                    |
|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| SR-H1 | Hardware Surface Reduction: The Gateway OS must enforce udev or equivalent kernel-level rules that explicitly disable unused USB interfaces.                                        | Reduces the risk of unauthorized keyboards, network adapters, storage devices, or other peripherals being introduced to the bare-metal Gateway. | udev ruleset review; unauthorized USB insertion test; allowed Hub port verification.                   |
| SR-H2 | Serial Isolation: The Gateway must interface with the physical CPS only through the dedicated Hub ESP32 tethered to the approved /dev/ttyUSB0 port.                                 | Ensures the Linux kernel does not directly process raw wireless spectrum traffic and keeps the Hub as the controlled serial chokepoint.         | /dev/ttyUSB0 mapping evidence; Hub firmware/connection test; absence of direct edge wireless adapters. |
| SR-H3 | Storage Resilience: High-volume logs and eBPF telemetry must be written to resilient USB 3.0 storage rather than MicroSD media.                                                     | Reduces write-endurance risk during logging-heavy experimentation and preserves availability of the Gateway.                                    | mount/path verification; logging path test; storage health or endurance notes.                         |
| SR-H4 | Safe Physical Failure State: The physical CPS must support a STOP or neutral actuation state if serial communication is severed, the daemon restarts, or a critical anomaly occurs. | Protects the physical environment when software or telemetry behavior becomes unsafe.                                                           | STOP test; daemon restart test; communication-loss response evidence.                                  |

## 6. Wireless Security and Integrity (SR-W)

Open-air communication between the Hub and edge vehicles must be protected against spoofing, injection, replay-like behavior, and unnecessary high-bandwidth exposure. The architecture favors encrypted ESP-NOW telemetry and analog light-sensor navigation over camera/video pipelines.

| ID    | Security Requirement                                                                                                                                                                                                                                           | Control Rationale                                                                                                                          | Validation Evidence                                                                                                    |
|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| SR-W1 | Deprecation of Visual Payloads: Visual camera processing and HTTP video streaming over Wi-Fi must be prohibited in the v10.0 architecture.                                                                                                                     | Eliminates high-bandwidth spoofing vectors, unmitigated video latency, rogue Access Point generation risk, and unnecessary attack surface. | Architecture review; firmware/UI review confirming no camera stream dependency; blocked/absent video service evidence. |
| SR-W2 | ESP-NOW Cryptography: Operational telemetry and motor commands transmitted over ESP-NOW must use CCMP encryption validated by a 16-byte Local Master Key (LMK).                                                                                                | Reduces risk of spoofed commands, injected telemetry, and unauthorized peer communication in the open-air wireless channel.                | Firmware configuration review; unauthorized peer rejection test; encrypted telemetry exchange test.                    |
| SR-W3 | Display Endpoint Segregation: The Smart TV used to render the physical track and Mission Control dashboard must be treated as a non-administrative endpoint. It may access TCP Port 8080 for rendering but must remain barred from TCP Port 22 SSH privileges. | Allows display functionality without granting management capability to a less trusted endpoint.                                            | Port 8080 allow test; Port 22 deny test; firewall rule review for TV MAC.                                              |

| ID    | Security Requirement                                                                                                                                          | Control Rationale                                                                 | Validation Evidence                                                                |
|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| SR-W4 | Approved Peer Restriction: ESP-NOW communication must be limited to approved Hub and edge peer identities, with unauthorized physical MAC addresses rejected. | Prevents uncontrolled edge devices from entering the command and telemetry plane. | Peer list review; rogue ESP32 test; rejected packet/absence of actuation evidence. |

## 7. Runtime Observability and Active Threat Mitigation (SR-O)

The system must maintain deep host visibility so attacks that bypass or abuse higher-level controls can still be detected and mitigated. The runtime security layer connects eBPF telemetry, AI scoring, and emergency physical safety response.

| ID    | Security Requirement                                                                                                                                                                                             | Control Rationale                                                                                                                       | Validation Evidence                                                                     |
|-------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| SR-O1 | Bare-Metal Tracing: Containerization such as Docker is explicitly prohibited for the Gateway C2 application. The application must run natively via systemd to preserve compatibility with eBPF syscall tracing.  | Avoids container abstraction that would interfere with direct host-level observability of serial read/write activity.                   | sentinel.service status; absence of Docker deployment; eBPF attach test.                |
| SR-O2 | Anomaly Detection: The localized AI model must evaluate kernel-level telemetry against baseline data, including expected analog PID thresholds, command frequency, and ESP-NOW packet frequency.                 | Detects malicious behavioral signatures that may bypass cryptographic validation or appear as abnormal but syntactically valid traffic. | Baseline dataset; anomaly score output; test with injected/replayed/DoS-like telemetry. |
| SR-O3 | Automated Severance: Upon detecting a critical anomaly, the Gateway must transmit an emergency STOP override to the Hub and execute an immediate fcntl lock or equivalent serial read/write severance mechanism. | Protects physical actuators by interrupting the command/telemetry chokepoint before unsafe behavior escalates.                          | STOP/severance test under load; serial lock evidence; recovery log.                     |
| SR-O4 | Audit Correlation: Application logs, serial traces, and anomaly decisions must be correlated by timestamp or event identifier whenever possible.                                                                 | Supports thesis validation, post-event review, and defensible explanation of detection/mitigation behavior.                             | Sample correlated log bundle; timestamp review; event reconstruction demonstration.     |

## 8. Security Validation Criteria

The SRD will be considered satisfied if the prototype can demonstrate the following outcomes under controlled lab conditions:

1. **Identity enforcement:** SSH password authentication is denied and administrative access succeeds only with authorized Ed25519 keys from approved endpoints.
2. **Perimeter segmentation:** nftables enforces default-drop behavior, restricts Port 22 and Port 8080 by role, and prevents the Gateway from functioning as a rogue bridge.
3. **mDNS availability:** iot-pi.local remains resolvable through avahi-daemon while other unnecessary network services remain minimized.
4. **Physical isolation:** Unused USB interfaces are blocked while the approved /dev/ttyUSB0 Hub path remains available and observable.
5. **Wireless integrity:** ESP-NOW communication rejects unauthorized peers and encrypted telemetry/command exchange remains limited to approved Hub-and-edge participants.

6. **Display least privilege:** The Smart TV can render the Port 8080 track/dashboard but cannot access SSH or administrative functions.
7. **Runtime mitigation:** eBPF-visible abnormal behavior can trigger AI scoring, emergency STOP, and serial severance behavior during simulated injection, replay, or DoS-like conditions.

## 9. Security Traceability Summary

| Security Area                  | Relevant Requirements      | Validation / Design Link                                                                             |
|--------------------------------|----------------------------|------------------------------------------------------------------------------------------------------|
| Administrative access control  | SR-A1, SR-A2, SR-A5        | Ed25519-only SSH, disabled password login, no admin credentials on display/sandbox endpoints         |
| Remote ingress control         | SR-A3, SR-A4, SR-N4        | University VPN and RDP Bastion Host workflow; no direct public Gateway exposure                      |
| Network perimeter defense      | SR-N1, SR-N2, SR-N3, SR-N5 | nftables default-drop HLAC, service-specific MAC whitelisting, mDNS resilience, service minimization |
| Physical and hardware safety   | SR-H1, SR-H2, SR-H3, SR-H4 | USB surface reduction, /dev/ttyUSB0 serial chokepoint, USB 3.0 storage, STOP-safe physical state     |
| Wireless integrity             | SR-W1, SR-W2, SR-W3, SR-W4 | No camera/video payloads, ESP-NOW CCMP/LMK, Smart TV display-only access, approved peer restriction  |
| Runtime detection and response | SR-O1, SR-O2, SR-O3, SR-O4 | Bare-metal eBPF tracing, AI anomaly scoring, fcntrl serial severance, correlated audit records       |

## Final Security Summary

The Sentinel-CPS security baseline combines identity enforcement, network segmentation, hardware reduction, encrypted edge telemetry, and host-level runtime observability into a single defensive architecture. The design does not rely on one control alone. Instead, it layers VPN/RDP ingress, Ed25519 SSH, nftables HLAC, Smart TV display segregation, serial chokepoint mediation, ESP-NOW cryptography, and eBPF/AI anomaly response to protect both the university network and the physical CPS environment.

These security requirements position Sentinel-CPS as a Zero-Trust remote educational CPS architecture: students and reviewers can interact with physical IoT concepts, but the Gateway, edge vehicles, and physical actuation path remain constrained by explicit trust boundaries and verifiable mitigation mechanisms.